SEGURIDAD DE LA INFORMACIÓN · TSI 2026 · PARTE 2

Evaluación Red Team
sistema-rsi

Prueba de penetración sobre el sistema de gestión del RSI del grupo DieAndres. 12 hallazgos confirmados con PoC real contra una instancia propia en laboratorio aislado.

Felipe Queirolo · Renzo Rampoldi

14/10 -> 09/11/2026

NestJS + Prisma/PostgreSQL + React/nginx

ALCANCE Y MÉTODO

01 Cómo se evaluó

- Caja negra -> caja de cristal: se revisó el código y se desplegó una instancia propia.
- Laboratorio aislado (Proxmox, red vmbr11 sin salida), datos 100% sintéticos, pruebas desde Kali.
- Cada hallazgo confirmado con PoC reproducible, no sólo lectura de código.
- Reglas de compromiso respetadas: sin producción, sin exfiltración real, DoS acotado, todo cambio revertido.

Estándares

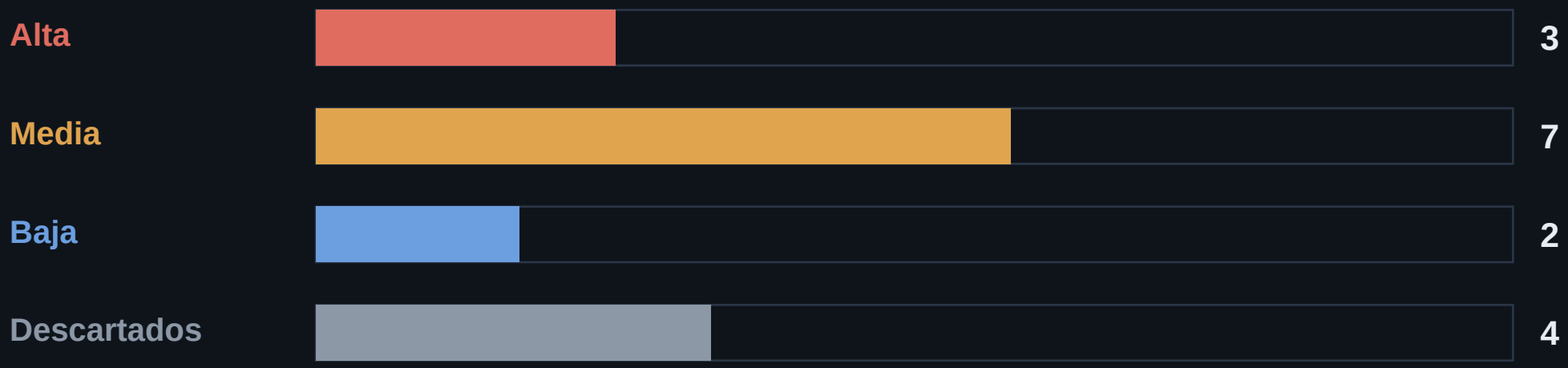
PTES · OWASP Testing Guide / Top 10 (2021) · MITRE ATT&CK · NIST SP 800-115. Clasificación OWASP + CWE, scoring CVSS v3.1.

Objetivos de la letra

9 de 12 objetivos RT cubiertos o cerrados · 3 parciales · 0 pendientes.

RESUMEN EJECUTIVO

02 Hallazgos por severidad



3 altos (CVSS 7.1-8.1), 7 medios, 2 bajos. 4 vectores descartados con justificación (XSS persistente, SQLi/SSTI, CSV injection, log injection). Postura: exposición media-alta concentrada en control de acceso.

EL MENSAJE PRINCIPAL

03 Una sola causa raíz explica la mayoría

> UnitScopeGuard resuelve el alcance organizativo por coincidencia de substring en la ruta -no por el recurso real- y solo restringe a DUENO_UNIDAD y LECTOR. Los roles RSI y ADMINISTRADOR quedan sin acotar.
>
> + Falta un ValidationPipe global con whitelist -> mass assignment.

De aquí salen H1, H2, H2b, H2c, H2d, H10 y RT05. Corregir la raíz realinea ~7 hallazgos y varias afirmaciones de cumplimiento a la vez.

DEMO - TOP 3 CRÍTICO (REPRODUCIBLE)

04 Los tres de mayor impacto

CVSS 8.1

H1 · Control de acceso roto

Un DUENO_UNIDAD lee y altera unidades, procesos y RACI de otras organizaciones. Demo: login rol bajo -> PATCH sobre unidad ajena -> 200.

CVSS 8.1

H2d · RSI sin alcance -> URCDP

El rol RSI accede a datos personales (Ley 18.331) de cualquier organización; KPIs sin segmentar. Demo: GET base personal de otra org -> 200.

CVSS 6.0

H3 · Backdoor de MFA

Mass assignment en PATCH /auth/usuarios/:id: plantar mfaSecret/hash sobre cualquier cuenta. Impacto de negocio alto: persistencia sigilosa.

Pasos completos en 05-reproduccion.md; PoC y evidencia en docs/evidencia/.

EFICACIA DE CONTROLES POR FUNCIÓN MCU 5.0

05 Dónde falla y dónde resiste

Gobernar
Aceptable
Roles y política definidos.

Identificar
Aceptable
Activos/riesgos/URCDP modelados.

Proteger
Débil
Autorización por alcance rota (núcleo).

Detectar
Débil
Sin alerta ante los ataques; SIEM no implementado.

Responder
Parcial
Auditoría de cambios sí; de lecturas no.

Recuperar
Parcial
Fuera del foco del ataque.

Funcionan: solo-lectura del LECTOR, no escalada de rol, CSRF/Origin, cookies __Host-, cifrado TOTP, sin SQLi, sin XSS.

RESPUESTA DEL BLUE TEAM · CUMPLIMIENTO

06 Lo declarado vs. lo observado

Afirmación del Blue Team	Observado	Veredicto
Mínimo privilegio / permisos por rol y ámbito	Rol bajo opera fuera de su ámbito (H1/H2c/H10)	Contradicha
Rol RSI acotado por ámbito	RSI sin alcance -> datos URCDP de otra org (H2d)	Contradicha
'Exigir MFA' como garantía de identidad	Mass assignment fabrica el MFA (H3)	Contradicha
Trazabilidad / SIEM	Sin alerta; ellos ya lo declaran pendiente	Brecha declarada
CSRF/Origin · LECTOR · cifrado TOTP · sin SQLi/XSS	Verificado correcto	Sostenida

3 contradichas · 3 parciales · 2 brechas declaradas · 5 sostenidas. Informe justo: se acreditan los controles que sí funcionan.

RECOMENDACIONES PRIORIZADAS POR RIESGO

07 Qué corregir primero

1 · Reescribir UnitScopeGuard

Resolver el recurso real y aplicar alcance a todos los roles, incluido RSI. Cierra H1/H2/H2c/H2d/H10/RT05 de raíz.

2 · ValidationPipe global

Whitelist + DTO explícito -> cierra el mass assignment (H3) y previene futuros.

3 · Cablear logging + alertas

Registrar accesos sobre AuditEvent y alertar escrituras cross-tenant. Habilita Detectar.

4 · Endurecer auth y exportadores

Anti-replay TOTP, tiempos de login parejos, escapar []() , paginar exportadores, segregar aprobación de riesgos.

REPRODUCIBILIDAD DEL LABORATORIO

08 Proxmox <-> Vagrant

Todos los hallazgos son a nivel aplicación: se reproducen igual en el lab de Vagrant (mismo docker-compose, misma migración y seed). Solo cambia la cáscara de infraestructura.

En el informe (Proxmox)	En el lab (Vagrant)
Target 10.10.10.87:8443	192.168.56.10:8443
Kali en bridge vmbr11	Red host-only (o 2a VM en vboxnet)
Credenciales del informe	Propias del provisioning (TOTP/Postgres por openssl)
Usuarios de rol bajo ya creados	Crearlos desde el panel admin
qm / SSH-jump / cloud-init	vagrant up / ssh / halt (no es PoC)

Se reproduce idéntico: H1, H2/2b/2c/2d, H3, H4/H4b, H9, H10, H11, RT03-MD, RT-04, RT-07, RT-11, RT-12.

ENTREGA FINAL

09 Qué se entrega

- Informe técnico en plantilla oficial de la cátedra.
- Inventario CVSS + guía de reproducción por hallazgo.
- Mapeo MITRE ATT&CK + capa para Navigator.
- Registro ISACA de incidentes (04) y vulnerabilidades (10).
- Informe de cumplimiento (contradicciones).
- Bitácora diaria firmada, con los fallos incluidos.
- Evidencia: PoC + capturas + laboratorio reproducible (Vagrant).

Gracias. Preguntas.

Resultado

3 altos 7 medios 2 bajos

Todos reproducibles. Una causa raíz dominante. Entorno restaurado.

Repositorio

github.com/fmq203/TSI-2026-RSI-redteam